

Penetration Test Report: Mediroza General Hospital

Oct 2, 2026

01. Executive Summary

A penetration test was conducted on the web infrastructure of Mediroza General Hospital. The objective was to assess the robustness of the security systems protecting sensitive data belonging to the facility, its staff, and its patients. The engagement revealed multiple critical vulnerabilities that allowed full compromise of the system. The overall impact is rated **CRITICAL**. Attackers were able to bypass authentication mechanisms, extract personally identifiable information (PII) belonging to staff, decrypt confidential patient medical records, and access internal financial data (employee salaries and shareholder details). Immediate action is required to secure the infrastructure.

02. Scope and Methodology

Target: Mediroza Hospital web application, database infrastructure, and document management (PDFs).

Methodology: Black-Box approach, simulating an external attacker with no prior access.

Tools used: Kali Linux environment; SQL query manipulation (SQL Injection); the online platform Networkwalks Password Cracker (<https://networkwalks.com/password-cracker/>) for hash extraction and password cracking (using public dictionaries); and ExifTool for forensic metadata analysis.

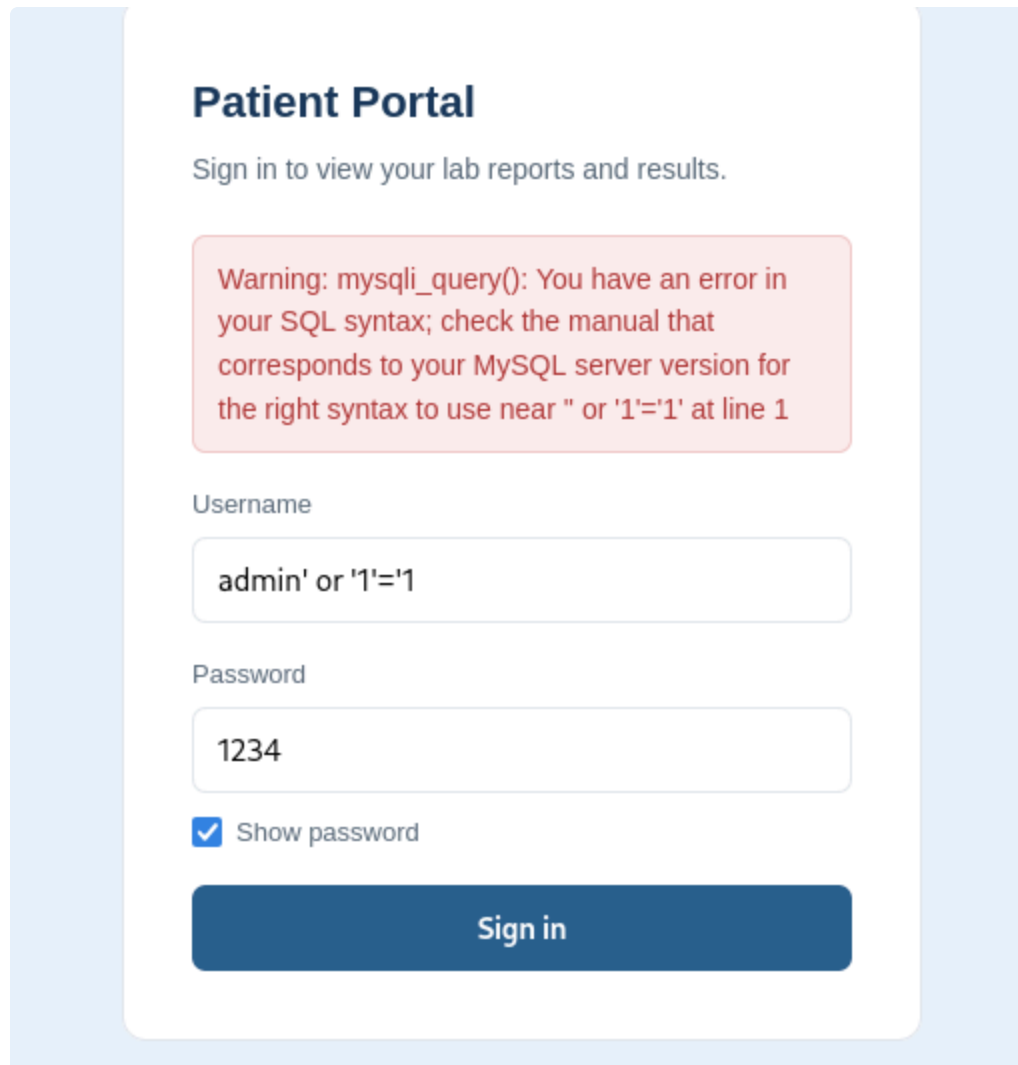
Limitations encountered: The analysis was limited to web and document-based attack vectors; no social engineering or physical attacks were included in the scope.

03. Findings and Proof of Exploitation

The test proceeded in three distinct phases, each leading to an escalation of privileges and data access.

Milestone M1: SQL Injection Vulnerability (Authentication Bypass)

Evidence: The web application did not properly sanitize user input. This flaw was exploited to bypass the patient login portal, which made it possible to run arbitrary queries against the database (MySQL) and extract the full `staff` table, containing the names, emails, phone numbers, national ID numbers, and salaries of all personnel.



The screenshot displays a web application interface for a 'Patient Portal'. At the top, the title 'Patient Portal' is followed by the instruction 'Sign in to view your lab reports and results.' Below this, a red warning box contains the message: 'Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near " or '1'='1' at line 1'. The login form consists of two input fields: 'Username' and 'Password'. The 'Username' field contains the text 'admin' or '1'='1', and the 'Password' field contains '1234'. Below the password field is a checkbox labeled 'Show password' which is checked. A blue 'Sign in' button is positioned at the bottom of the form.

Figure 1 — Patient Portal: `admin' or '1'='1` injected in the login form, triggering a MySQL syntax error and bypassing authentication.

Milestone M2: Weak Password Policies on Encrypted Documents

Evidence: Three pathology reports in PDF format were encrypted (Standard V2.3, 128-bit). The passwords were compromised using the Networkwalks online tool, relying on dictionary attacks, demonstrating poor security practices:

- **Report 1 (Sipho Dlamini):** Cracked via a standard dictionary attack, revealing the trivial password `123456`.
- **Report 2 (Priya Reddy):** Cracked the same way as the first report, via a dictionary attack, also revealing a weak password.
- **Report 3:** Successfully cracked using the standard public `rockyou.txt` dictionary, revealing the sequence `!@#%$^&`.

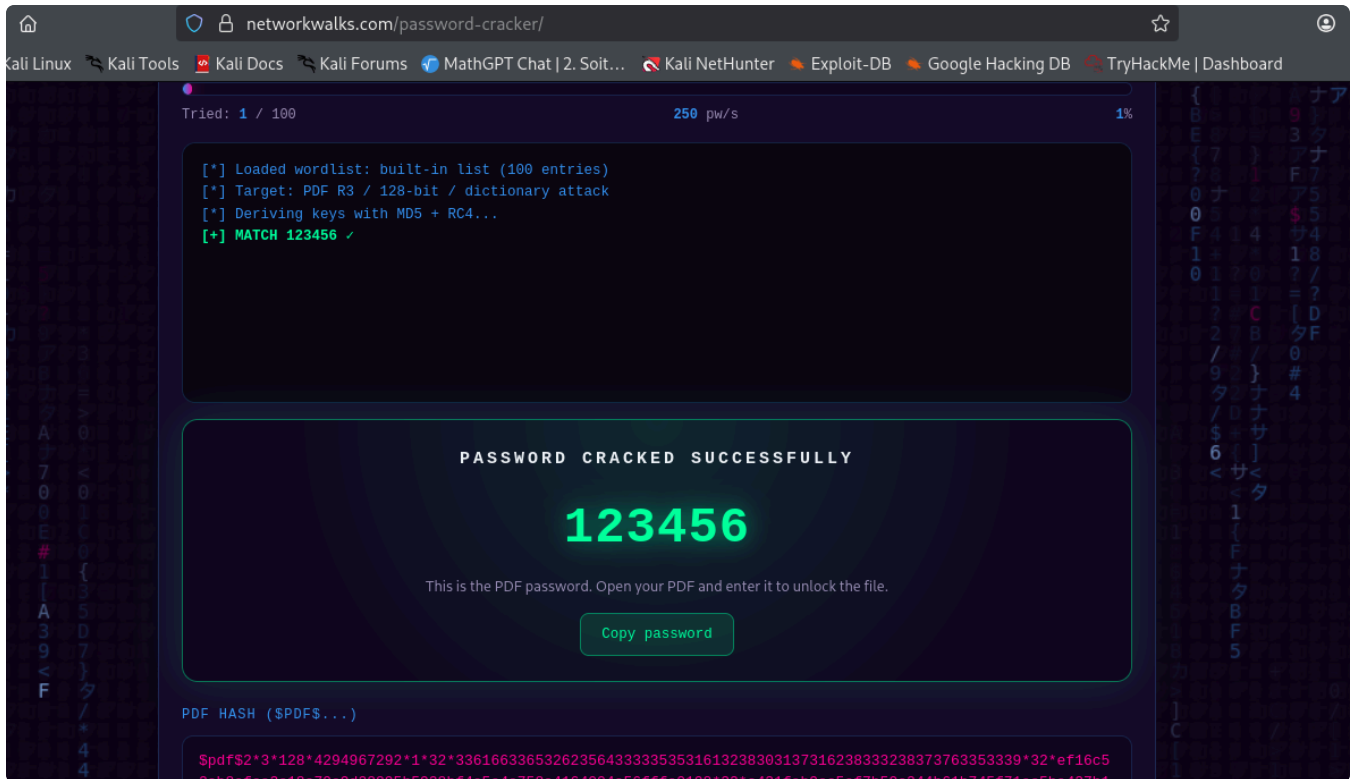


Figure 2 — Networkwalks Password Cracker: dictionary attack against Report 1's PDF encryption, recovering the password `123456` in under a second.

Milestone M3: Information Leak via Metadata and Backup Exposure

Evidence: Analysis of the internal metadata of the unlocked PDF files using ExifTool revealed a comment from a system administrator (j.malik) indicating that a database backup had been moved to an `/old` directory during a migration. Browsing to the URL path `http://[target]/old` allowed the full backup to be downloaded without any authentication, exposing critical details about the hospital's shareholders.

```

noussaiba@kali: ~/Desktop/Intern/week4/M1
Session Actions Edit View Help

(noussaiba@kali)-[~/Desktop/Intern/week4/M1]
$ exiftool -password '!@#$$%^&' patient_report_3.pdf
ExifTool Version Number      : 13.50
File Name                    : patient_report_3.pdf
Directory                    : .
File Size                    : 3.7 kB
File Modification Date/Time   : 2026:09:30 19:21:12+01:00
File Access Date/Time        : 2026:10:01 22:14:38+01:00
File Inode Change Date/Time   : 2026:09:30 19:22:43+01:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Encryption                   : Standard V2.3 (128-bit)
User Access                  : Print, Modify, Copy, Annotate, Fill forms, Extract, Assemble, Print hig
h-res
Page Count                   : 1
Producer                     : Mediroza Lab Reporting Module
Title                         : Pathology Report - E. Thompson
Author                       : j.malik
Subject                       : Full Blood Count
Creator                      : Mediroza CMS 1.4.2
Keywords                     : pathology, patient report
Comments                     : DB backup moved to /old before site migration, do not delete

(noussaiba@kali)-[~/Desktop/Intern/week4/M1]
$

```

Figure 3 — ExifTool output on the decrypted PDF: the Comments field left by j.malik discloses the `/old` backup path.

04. Risk Rating

The following classification details the severity of the vulnerabilities discovered.

Vulnerability Identified	Risk Level	Justification
SQL Injection (SQLi)	Critical	Allows remote code execution against the database, massive PII leakage, and full compromise of system integrity.
Backup Exposure (Directory Listing / Backup exposure)	Critical	Public access to a database archive in <code>/old</code> instantly exposes intellectual property and financial data (shareholders, salaries) without requiring advanced hacking skills.

Vulnerability Identified	Risk Level	Justification
Weak Document Encryption (Password Policy)	High	The use of keyboard sequences (!@#\$\$%^&) or numeric strings (123456) renders 128-bit AES/RC4 encryption useless. Exposes confidential patient medical records, in violation of healthcare regulations.
Metadata Leak (Information Disclosure)	Medium	Internal comments left in PDF files generated by the system provided the access map (the /old directory) leading to the most severe compromise.

05. Recommendations and Remediation

To secure Mediroza’s infrastructure, the following corrective actions must be applied immediately:

- 1. Database Sanitization (SQLi Remediation):** Implement parameterized queries (Prepared Statements) or use an ORM (Object-Relational Mapping) for all database interactions to neutralize any SQL injection attempt.
- 2. Securing Directories and Backups:** Immediately remove the /old directory from the public web server. Backups must be stored offline, encrypted at rest, or placed on storage servers inaccessible from the public network.
- 3. Enforcing Strong Password Policies:** Require administrators and the PDF generation system to use complex, randomly generated passwords of at least 12 characters, combining uppercase, lowercase, digits, and special characters. Block the use of passwords found in public dictionaries (such as rockyou.txt).
- 4. Automated Metadata Cleanup:** Configure the PDF creation module (Mediroza CMS) to systematically purge (data scrubbing) internal metadata, comments, and author names before delivering documents to end users.